

MODULE 05

权限、沙箱与安全架构

从 prompt 规则到 OS 强制边界：deny-first、hooks、路径与企业策略

安全不是让模型“记得小心”，而是把不可接受的行为做成确定性阻断，把有歧义的行为上报给人，把剩余能力限制在可恢复边界内。

研究基线：Claude Code v2.1.236（稳定版） | Python Agent SDK v0.2.141（tag） | 历史源码观察 v2.1.88
资料核验日期：2026-08-19 | 中文深度研究版

目录

- 1. 七层纵深防御
- 2. 规则判定：deny → ask → allow
- 3. 七种 permission mode
- 4. Read/Edit 规则与路径语义
- 5. OS sandbox：Seatbelt / bubblewrap + network proxy
- 6. Hooks 在安全管线中的位置
- 7. 命令与路径注入的源码级教训
- 8. 企业 managed policy
- 9. Threat model 与控制矩阵
- 10. 安全部署 checklist

阅读提示：内部模块名以历史源码观察解释，当前功能以官方文档与 v0.2.141 SDK 源码校验。

1. 七层纵深防御

层	机制	阻断对象	是否依赖模型
1	system safety instructions	明显不合规意图	是
2	tool schema/结构解析	畸形调用	否
3	命令静态验证	危险 shell 结构	否
4	permission rules/modes	未授权工具/参数	否
5	path/domain constraints	越界文件与网络	否
6	hooks/classifier/human approval	上下文相关风险	部分
7	OS sandbox	Bash 子进程真实访问	否

历史源码分析把层次细分到 Bash AST validator、filesystem guards 和 sandbox manager；当前官方文档确认 permission 与 sandbox 是互补边界：前者覆盖工具决策，后者只对 shell 及其子进程做 OS 级文件/网络限制。 [O5, O6, R2]

2. 规则判定：deny → ask → allow

规则由工具名与参数模式组成，例如 `Bash(git status)`、`Read(/src/**)`、`WebFetch(domain:example.com)`。deny 在任何作用域都不能被 allow 覆盖；ask 把决定交给交互 UI、SDK `can_use_tool` 或 permission prompt MCP tool。 [O5, S2, S5]

规则	含义	注意
bare tool deny	从可用工具目录移除	模型通常看不到该工具
scoped deny	工具仍可见，但特定调用拒绝	适合 Bash/Read 参数约束
allow	免提示执行	不是绕过更高层 deny
ask	每次或按规则询问	批准结果可能写入对应 scope

关键区别

`can_use_tool` 只接到原本会 ask 的调用；已经被 allow、acceptEdits 或 bypass 放行的调用不会经过它。想观察/拦截每一次工具调用，应使用 PreToolUse hook。 [S5]

3. 七种 permission mode

模式	默认行为	适合	主要风险
plan	只读探索/计划	方案评审	计划文本不等于执行隔离全部正确
default	首次危险操作询问	日常交互	批准疲劳
acceptEdits	工作区编辑与常见 FS 自动	受信仓库	脚本仍可产生更大副作用
auto	安全分类器代替大部分询问	订阅计划的低摩擦工作	分类器成本与误判
dontAsk	未预批准的一律拒绝	CI/无人值守	配置遗漏导致能力不足
bypassPermissions	跳过大多数提示	隔离容器/VM	宿主暴露时危险
bubble	子 agent 向父级上报	内部委托	不是用户可依赖的稳定 public mode

当前官方列出前六种用户模式；bubble 来源于历史源码观察。恢复会话时 plan 与 bypass 不自动恢复，auto 也要重新满足账号条件。这是“恢复内容但不恢复高风险授权”的重要安全不变量。 [O5, O11, R1]

4. Read/Edit 规则与路径语义

模式	相对基准	示例
//path	文件系统根	Read(//Users/alice/secrets/**)
~/path	用户 home	Read(~/Documents/*.pdf)
/path	项目根	Edit(/src/**/*.ts)
path / ./path	当前目录	Read(*.env)

Read/Edit deny 对内置文件工具有效，但不能单独阻止 Bash cat。若要统一封锁秘密文件，必须启用 sandbox；当前 v2.1.236 又修复 macOS 上 wildcard deny 在 allow region 内的优先级、目录内容覆盖和重命名绕过。 [O1, O5, O6]

5. OS sandbox: Seatbelt / bubblewrap + network proxy

- 默认写：cwd 及子目录；额外路径通过 allowWrite/additional directories 配置。
- 默认读：较宽，但合并 Read deny 与 sandbox denyRead 形成最终边界。
- macOS 用 Seatbelt，Linux 用 bubblewrap；WSL2 支持，原生 Windows 路线取决于当前版本工具。
- 网络经 sandbox 外代理按域名允许/拒绝，不做 TLS 内容检查。
- failIfUnavailable=true 可把缺 bubblewrap/socat 从警告降级改为硬失败。 [O6]

Auto-allow sandboxed Bash 的逻辑是用 OS 边界替代逐命令批准；显式 deny 仍生效。不能 sandbox 的命令可请求 dangerouslyDisableSandbox 走普通权限流；可用 allowUnsandboxedCommands=false 关闭逃生口。 [O5, O6]

示例 | 高约束环境示例

```
{
  "sandbox": {
    "enabled": true,
    "failIfUnavailable": true,
    "allowUnsandboxedCommands": false
  }
}
```

```
},
"permissions": {
  "deny": ["Read(**/.env)", "Bash(curl *)"]
}
}
```

6. Hooks 在安全管线中的位置

Hook	用途	决策能力
PreToolUse	执行前验证/修改/拒绝	可阻断
PermissionRequest	接管批准 UI/策略	允许或拒绝
PostToolUse	审计、格式化、补充 context	不能撤销既有副作用
PostToolUseFailure	分类失败、告警	可指导下一步
Stop/SubagentStop	完成门禁	可要求继续
ConfigChange/SessionStart	策略变化与启动注入	观察/追加 context

当前 hooks 可由 shell、HTTP、MCP tool、LLM prompt 或 agent handler 承担。安全敏感 hook 要设置 timeout、校验输入 schema、限制输出大小，并避免把不可信 hook 文本当成更高优先级指令。[O17]

7. 命令与路径注入的源码级教训

- SDK 对 `--resume`、`session_id`、`resume_session_at` 使用 equals form，防止 dash-leading value 注入新 CLI flag。
- skill name 拒绝逗号、空白、括号、通配符等，因为它最终会进入 comma-separated allowedTools。
- Windows 拒绝任何路径组件含 `.cmd/`、`.bat`、ADS/colon 与尾随点空格变体，防止执行 shim 或路径解析偏差。
- SessionStore materialization 校验 UUID 和 subpath，拒绝 absolute、`...`、drive/UNC 和解析后越界。
- session rename/tag 做 Unicode NFKC 与危险格式字符清理，降低不可见字符欺骗。[S1, S3, S5, S7]

8. 企业 managed policy

- `allowManagedHooksOnly`：只加载 managed、SDK 与强制插件 hooks。
- `allowManagedMcpServersOnly`：只允许托管 MCP allowlist，deny 仍全局合并。
- `allowManagedPermissionRulesOnly`：阻止用户/项目定义 allow/ask/deny。
- `sandbox allowManaged*Only`：防止项目扩大读路径或网络域名。
- `strictKnownMarketplaces / blockedMarketplaces`：下载前阻断未批准来源。
- `forceRemoteSettingsRefresh`：拿不到最新远端策略则启动失败，实现 fail closed。[O4, O5]

9. Threat model 与控制矩阵

威胁	首要控制	残余风险
仓库 prompt injection	workspace trust + deny + sandbox	用户主动批准高危操作
恶意依赖 postinstall	network/FS sandbox	允许域名上的供应链攻击
MCP tool 过权	MCP allowlist + tool permission	server 返回不可信文本
插件提前执行	managed marketplace + trust gate	历史预信任窗口类漏洞
会话恢复越权	不恢复 bypass/plan，重新加载策略	旧 transcript 含恶意内容
凭据外泄	denyRead + sandbox + env 最小化	已允许进程可访问授权域

10. 安全部署 checklist

- 固定版本；先在 staging 验证 changelog 中 permission/sandbox 变化。
- CI 用 dontAsk + 明确 allowlist，不用 bypass。
- 容器内仍启用文件与网络边界；容器不是自动安全。
- 把 secret 放到按需 credential helper，不写入 CLAUDE.md/skill。
- 记录 tool_decision、permission denial、sandbox violation 和 hook result。
- 定期从 transcript 生成最小 allowlist，并人工审核后进入 managed policy。

参考资料与证据等级

[O4] 官方 | [Settings reference](#)

<https://code.claude.com/docs/en/settings>

[O5] 官方 | [Permissions](#)

<https://code.claude.com/docs/en/permissions>

[O6] 官方 | [Sandboxing](#)

<https://code.claude.com/docs/en/sandboxing>

[O17] 官方 | [Hooks reference](#)

<https://code.claude.com/docs/en/hooks>

[S2] 开源源码 | [Internal Query control protocol](#)

https://github.com/anthropics/claude-agent-sdk-python/blob/v0.2.141/src/claude_agent_sdk/_internal/query.py

[S3] 开源源码 | [Subprocess CLI transport](#)

https://github.com/anthropics/claude-agent-sdk-python/blob/v0.2.141/src/claude_agent_sdk/_internal/transport/subprocess_cli.py

[S5] 开源源码 | [SDK types and options](#)

https://github.com/anthropics/claude-agent-sdk-python/blob/v0.2.141/src/claude_agent_sdk/types.py

[R1] 社区研究 | [Dive into Claude Code v2.1.88](#)

<https://github.com/VILA-Lab/Dive-into-Claude-Code>

[R2] 社区研究 | [Claude Code Research - source analysis](#)

<https://github.com/cablate/claude-code-research>

方法说明

官方材料用于确认当前稳定行为；SDK 源码固定在发布 tag v0.2.141；社区材料只用于解释 v2.1.88 历史源码结构。源码行号和内部函数名可能在后续版本变化，外部契约以官方最新文档为准。